

Phase 5 - Security

Time	Start date	Finish date	Status
1.5 weeks			Not started

Goal: Real login and correct permissions for Student, Volunteer, Organizer and Admin.

Real-life example: The college gate: everyone shows an ID card, and each ID card opens only certain rooms.

Step checklist

#	Step	Done
1	Register API with BCrypt password hashing	☐
2	Login API that sends a JWT inside an httpOnly cookie; logout clears it	☐
3	JWT filter in Spring Security that reads the cookie on every request	☐
4	CSRF protection with a CSRF cookie that Axios sends back	☐
5	Roles: STUDENT and ADMIN; club roles: ORGANIZER and VOLUNTEER (per club)	☐
6	Protect every API by role - for example only organizers of that club can edit its events	☐
7	React: auth slice in Redux, protected routes, hide buttons the user cannot use	☐
8	Audit log: record who approved, rejected or edited events	☐
9	Rate-limit the login API to stop password guessing	☐

Output of this phase

- Working register / login / logout
- Role-based access on backend and frontend

Done when (check before moving on)

Check	Passed
A student gets 403 on admin APIs; an admin gets 200	☐
An organizer of Coding Club cannot edit Dance Club events	☐

Skills you practise

Spring Security, JWT, cookies, CSRF, authentication vs authorization

Where your work goes

backend\...\auth\ and security config; frontend auth slice and protected routes

My notes
